

acme-demo — security & access hygiene

Generated 25 Aug 2026, 12:00 UTC · Activity window: last 180 days · 5 repositories scanned, 1 skipped · Run #2

The short version

- **4 critical or high severity vulnerabilities are still open** across 3 repositories. The oldest has been open for 347 days.
- **10 access grants look stale** — 2 of them at **admin** level. These are suggestions for human review; nothing has been changed.
- 13 people were assessed across 5 repositories. 10 access grants were deliberately held back from the suggestions — org owners, bots, allowlisted accounts, and repositories too new or too small to judge fairly. All of them are listed in section 4.

4

Critical + high, open

8

Open advisories, all severities

10

Suggested access removals

2

Of those, admin access

5

Repositories scanned

13

People assessed

1 Security advisories

Every Dependabot alert across the organization, grouped by how serious it is and whether anyone has dealt with it. **Open** means still exploitable today.

Open alerts by severity



■ Critical ■ High ■ Medium ■ Low

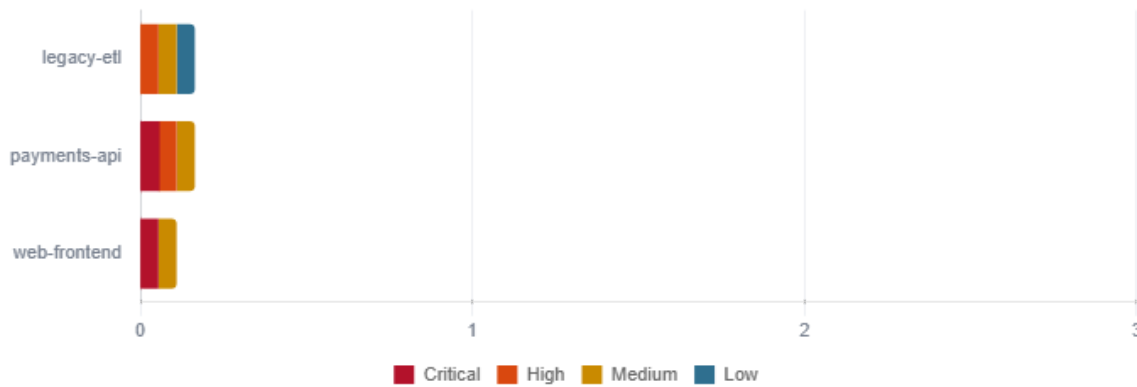
SEVERITY	OPEN	FIXED	DISMISSED
Critical	2	0	0
High	2	1	0
Medium	3	0	0
Low	1	0	1

Status of all alerts



10 alerts total. Dismissed alerts were closed by a person or a rule without a fix — worth spot-checking.

Most affected repositories



Oldest unresolved alerts

Sorted by how long they have been open. These are the ones that have been ignored the longest.

AGE	SEVERITY	PACKAGE	REPOSITORY	ADVISORY	SUMMARY
347d	Critical	django pip	acme-demo/payments-api	GHSA-7q4j-hf2p-1x2m CVE-2025-38412	Django SQL injection via crafted QuerySet lookups
278d	High	pyyaml pip	acme-demo/legacy-etl archived	GHSA-59hf-2m3x-6q8p CVE-2025-41200	PyYAML arbitrary code execution via full_load
194d	Low	six pip	acme-demo/legacy-etl archived	GHSA-w8q7-3r5t-2n6v CVE-2026-10044	six insecure temporary file usage
164d	Critical	next npm	acme-demo/web-frontend	GHSA-vv6q-4m2j-7d8s CVE-2026-30122	Next.js middleware authorization bypass
137d	Medium	jinja2 pip	acme-demo/legacy-etl archived	GHSA-6x2c-9v4h-5j3k CVE-2026-15533	Jinja2 sandbox escape via str.format
114d	High	urllib3 pip	acme-demo/payments-api	GHSA-2wvc-8f3r-9k4d CVE-2026-11907	urllib3 leaks Authorization header on cross-origin redirect
67d	Medium	lodash npm	acme-demo/payments-api	GHSA-mv84-cc32-8x5q CVE-2026-20355	lodash prototype pollution in defaultsDeep
55d	Medium	postcss npm	acme-demo/web-frontend	GHSA-8jrx-5c9w-4f2n CVE-2026-31880	postcss line return parsing error

2 Who has access, and what they did with it

One row per person per repository. **Score** combines commits, reviews and pull requests over the last 180 days, with older work counting for less. A score below **5.0** triggers a review suggestion. Repositories are ordered by how many suggestions they produced. Click any repository to expand it.

payments-api

private

3 open alerts

5 to review

10 with access

Created 04 Mar 2021 · last push 24 Aug 2026 · 99 commits in window from 5 identified contributors · 7 commits could not be attributed (commit email not linked to any GitHub account — deliberately not guessed) · open on GitHub

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
lena-active	Direct (Write)	62	9	14	24 Aug 2026 (0 days ago)	26.29	active

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
dependabot[bot]	Direct (Write)	24	0	22	23 Aug 2026 (2 days ago)	18.97	excluded — Bot or app account
priya-staff	Direct (Maintain)	2	21	1	20 Aug 2026 (5 days ago)	13.25	active
ravi-owner	Direct (Admin)	1	2	0	11 Jun 2026 (75 days ago)	3.61	excluded — Organization owner
dev-vendor	Outside collaborator (Write)	3	0	1	05 Mar 2026 (172 days ago)	3.21	review access
alex-departed	Direct (Admin)	0	0	0	17 Apr 2025 (495 days ago) before the window	0.00	review access
audit-svc	Direct (Read)	0	0	0	never	0.00	excluded — On the configured allowlist
maya-platform	Team: Platform Engineering (Write) team-inherited	0	0	0	30 Aug 2025 (360 days ago) before the window	0.00	review access
sam-stale	Direct (Write)	0	0	0	14 Nov 2025 (283 days ago) before the window	0.00	review access
tom-triage	Direct (Triage)	0	0	0	never	0.00	review access

▼ legacy-etl private archived 3 open alerts 4 to review 5 with access

Created 22 Jan 2019 · last push 02 Apr 2026 · 15 commits in window from 2 identified contributors · 12 commits could not be attributed (commit email not linked to any GitHub account — deliberately not guessed) · open on GitHub

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
ravi-owner	Direct (Admin)	1	0	1	02 Apr 2026 (145 days ago)	2.38	excluded — Organization owner
kai-solo	Direct (Write)	2	0	0	19 Mar 2026 (159 days ago)	2.16	review access

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
maya-platform	Team: Data Engineering (Maintain) team-inherited	0	0	0	08 Nov 2023 (1020 days ago) before the window	0.00	review access
sam-stale	Direct (Admin)	0	0	0	02 Jun 2024 (814 days ago) before the window	0.00	review access
tom-triage	Direct (Read)	0	0	0	never	0.00	review access

- ▼ web-frontend

2 open alerts

1 to review

5 with access

Created 19 Jul 2022 · last push 25 Aug 2026 · 30 commits in window from 4 identified contributors · **2 commits could not be attributed** (commit email not linked to any GitHub account — deliberately not guessed) · [open on GitHub](#)

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
release-bot	Direct (Write)	15	0	15	25 Aug 2026 (0 days ago)	16.62	excluded — Bot or app account
lena-active	Direct (Maintain)	8	4	3	14 Aug 2026 (11 days ago)	14.16	active
noor-new	Direct (Write)	5	1	2	19 Aug 2026 (6 days ago)	10.16	active
priya-staff	Team: Frontend Guild (Write) team-inherited	0	11	0	30 Jul 2026 (26 days ago)	5.62	active
alex-departed	Team: Platform Engineering (Write) team-inherited	0	0	0	21 Jun 2025 (429 days ago) before the window	0.00	review access

- ▼ infra-scripts

private

access looks current

2 with access

No removal suggestions for this repository. Only 1 contributor in the window. With no one to compare against, a low score says nothing useful.

Created 02 May 2023 · last push 11 Aug 2026 · 32 commits in window from 1 identified contributor · **1 commits could not be attributed** (commit email not linked to any GitHub account — deliberately not guessed) · [open on GitHub](#)

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
kai-solo	Direct (Admin)	31	0	4	11 Aug 2026 (14 days ago)	14.43	excluded — Repository has only one contributor
tom-triage	Direct (Write)	0	0	0	19 Feb 2024 (918 days ago) before the window	0.00	excluded — Repository has only one contributor

ml-sandbox

private

access looks current

3 with access

No removal suggestions for this repository.

Created 28 days ago, inside the 180-day window. Nobody has had time to build a history here yet.

Created 28 Jul 2026 · last push 22 Aug 2026 · 15 commits in window from 2 identified contributors · open on GitHub

MEMBER	HOW THEY HAVE ACCESS	COMMITTS	PRS REVIEWED	PRS MERGED	LAST ACTIVITY	SCORE	STATUS
noor-new	Direct (Admin)	12	0	2	22 Aug 2026 (3 days ago)	11.14	excluded — Repository created within the last 180 days
lena-active	Direct (Write)	3	1	1	06 Aug 2026 (19 days ago)	7.41	excluded — Repository created within the last 180 days
alex-departed	Direct (Write)	0	0	0	never	0.00	excluded — Repository created within the last 180 days

3 Suggested access removals

Ranked by **risk** = how much power the grant carries, divided by how much the person is using it. A dormant admin ranks above a dormant reader. **Nothing here has been changed** — this tool never revokes access. Every row is a recommendation for a human to confirm.

#	MEMBER	REPOSITORY	PERMISSION	LAST COMMIT	LAST REVIEW	SCORE	RISK	WHY FLAGGED	WHAT TO DO
1	alex-departed	payments-api	Admin	17 Apr 2025 (495 days ago) before the window	never	0.00	3.00	Holds admin access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone.
2	sam-stale	legacy-etl archived	Admin	02 Jun 2024 (814 days ago) before the window	never	0.00	3.00	Holds admin access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone. The repository is archived, and GitHub refuses collaborator changes while it is - remove the grant at the org or team level, or unarchive, revoke, and re-archive.

#	MEMBER	REPOSITORY	PERMISSION	LAST COMMIT	LAST REVIEW	SCORE	RISK	WHY FLAGGED	WHAT TO DO
3	maya-platform	legacy-etl archived	Maintain via Data Engineering	08 Nov 2023 (1020 days ago) before the window	never	0.00	2.00	Holds maintain access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Access is inherited from Data Engineering. Removing it means changing team membership, which affects every repo that team can reach - review at the team level, not here. The repository is archived, and GitHub refuses collaborator changes while it is - remove the grant at the org or team level, or unarchive, revoke, and re-archive.
4	alex-departed	web-frontend	Write via Platform Engineering	21 Jun 2025 (429 days ago) before the window	never	0.00	1.50	Holds write access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Access is inherited from Platform Engineering. Removing it means changing team membership, which affects every repo that team can reach - review at the team level, not here.

#	MEMBER	REPOSITORY	PERMISSION	LAST COMMIT	LAST REVIEW	SCORE	RISK	WHY FLAGGED	WHAT TO DO
5	maya-platform	payments-api	Write via Platform Engineering	30 Aug 2025 (360 days ago) before the window	never	0.00	1.50	Holds write access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Access is inherited from Platform Engineering. Removing it means changing team membership, which affects every repo that team can reach - review at the team level, not here.
6	sam-stale	payments-api	Write	14 Nov 2025 (283 days ago) before the window	never	0.00	1.50	Holds write access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone.
7	tom-triage	payments-api	Triage	never	never	0.00	0.50	Holds triage access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone.

#	MEMBER	REPOSITORY	PERMISSION	LAST COMMIT	LAST REVIEW	SCORE	RISK	WHY FLAGGED	WHAT TO DO
8	tom-triage	legacy-etl archived	Read	never	never	0.00	0.50	Holds read access but has no recorded commits, reviews or pull requests in the last 180 days. Score 0.00 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone. The repository is archived, and GitHub refuses collaborator changes while it is - remove the grant at the org or team level, or unarchive, revoke, and re-archive.
9	kai-solo	legacy-etl archived	Write	19 Mar 2026 (159 days ago)	never	2.16	0.47	Holds write access but last contributed 159 days ago (2 commits, 0 PRs reviewed, 0 PRs merged in the window). Score 2.16 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone. The repository is archived, and GitHub refuses collaborator changes while it is - remove the grant at the org or team level, or unarchive, revoke, and re-archive.

#	MEMBER	REPOSITORY	PERMISSION	LAST COMMIT	LAST REVIEW	SCORE	RISK	WHY FLAGGED	WHAT TO DO
10	dev-vendor	payments-api	Write	05 Mar 2026 (172 days ago)	never	3.21	0.36	Holds write access but last contributed 172 days ago (3 commits, 0 PRs reviewed, 1 PR merged in the window). Score 3.21 is below the 5.0 threshold.	Direct repository grant; can be revoked on this repo alone.

4 Who was excluded, and why

These people and repositories were deliberately kept out of the suggestions above. This panel exists so the list you just read can be trusted: if you cannot see who was skipped, you have no way to know whether the tool is hiding something.

People never suggested for removal (10)

On the configured allowlist (1)

audit-svc	acme-demo/payments-api	Read
-----------	------------------------	------

Bot or app account (2)

dependabot[bot]	acme-demo/payments-api	Write
release-bot	acme-demo/web-frontend	Write

Organization owner (2)

ravi-owner	acme-demo/legacy-etl	Admin
ravi-owner	acme-demo/payments-api	Admin

Repository created within the last 180 days (3)

alex-departed	acme-demo/ml-sandbox	Write
lena-active	acme-demo/ml-sandbox	Write
noor-new	acme-demo/ml-sandbox	Admin

Repository has only one contributor (2)

kai-solo	acme-demo/infra-scripts	Admin
tom-triage	acme-demo/infra-scripts	Write

Repositories and how they were treated

Repository is archived (1)

legacy-etl	Archived, but still scanned - access on an archived repo is still live access, and anyone holding it can unarchive the repo.
------------	--

Repository is a fork (1)

vendor-sdk-fork	fork (SKIP_FORKS is on)
-----------------	-------------------------

Repository created within the last 180 days (1)

ml-sandbox	Created 28 days ago, inside the 180-day window. Nobody has had time to build a history here yet.
------------	--

Repository has only one contributor (1)

infra-scripts	Only 1 contributor in the window. With no one to compare against, a low score says nothing useful.
---------------	--

Unattributed commits (22)

Commits whose author email is not linked to any GitHub account. They are counted and reported but never assigned to a person, because guessing would credit — or fail to credit — the wrong someone.

Scoring: $\text{activity} = 3.0 \cdot \ln(1 + \text{commits}) + 2.5 \cdot \ln(1 + \text{reviews}) + 2.0 \cdot \ln(1 + \text{PRs merged}) + 1.0 \cdot \ln(1 + \text{PRs opened})$, then halved for every 180 days since the person's last activity. $\text{risk} = \text{permission weight} \div (1 + \text{score})$, where admin=3, maintain=2, write=1.5, triage/read=0.5. Flagged below 5.0.

Run #2 · started 2026-08-27T19:55:48+00:00 · database keyed on GitHub IDs, so re-running updates this report in place rather than duplicating it. Access removal is always a suggestion, never an automatic action.